

ACTIVIDAD 01 – ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Caso: Aurora Market

Nombre completo: Natacha Yael Lucas

Fecha: 05 de septiembre de 2026

Programa: Hacker Women Council – Ethical Hacking

1. OBJETIVO DEL PENTEST

El objetivo de este pentest es brindarle a Aurora Market una evaluación objetiva de la seguridad real de su aplicación web, más allá de las correcciones puntuales que el equipo de tecnología fue aplicando conforme surgían los problemas hasta el momento. La empresa nunca realizó una auditoría formal de seguridad, y el incidente reportado recientemente —un usuario que asegura haber visto información perteneciente a otra cuenta— es una señal de alerta que el equipo interno no pudo explicar ni descartar como un problema de control de acceso, de permisos, de configuración o de una vulnerabilidad real. Esa incertidumbre es justamente lo que motiva la contratación de una evaluación formal: Aurora Market necesita saber, con evidencia, qué tan expuesta está su plataforma.

Concretamente, esta evaluación busca:

- **Investigar el incidente reportado.** Determinar si existe una falla real de control de acceso que permita a un usuario visualizar información de otra cuenta, entender su causa raíz (error de aplicación, de permisos, de configuración o vulnerabilidad explotable) y dimensionar su alcance real.
- **Evaluar de forma sistemática la seguridad de la aplicación.** Auditar las funcionalidades críticas de la plataforma (autenticación, gestión de usuarios, catálogo, carrito, checkout y panel de administración) para identificar vulnerabilidades adicionales que un atacante podría aprovechar, incluso si nunca fueron reportadas por un usuario.
- **Traducir los hallazgos en decisiones de seguridad.** Documentar cada vulnerabilidad encontrada con su nivel de riesgo, su impacto potencial y recomendaciones técnicas concretas, de forma que el equipo de desarrollo de Aurora Market pueda priorizar y corregir los problemas reales, en lugar de seguir reaccionando a incidentes aislados.

El valor que esto representa para Aurora Market es doble. Por un lado, reduce el riesgo de una filtración real de datos de miles de clientes —nombres, correos electrónicos, teléfonos, direcciones de envío e historial de compras—, cuya exposición implicaría pérdida de confianza y daño reputacional para la empresa. Por otro lado, le permite a la empresa pasar de un modelo puramente reactivo ("corregimos cuando aparece un problema") a uno preventivo, con visibilidad real sobre su exposición ante posibles ataques antes de que estos ocurran.

2. ALCANCE

Sí se evaluará

- Aplicación web de Aurora Market.
- Módulos de autenticación, gestión de perfil, registro de usuarios e historial de pedidos.
- Panel de administración para empleados (gestión de productos, usuarios y pedidos).
- API / endpoints asociados a la plataforma web.

Fuera del alcance

- Redes sociales de Aurora Market.
- Equipos personales de empleados o clientes.

- Cuentas de correo electrónico de la empresa o empleados.
- Proveedores externos.
- Sistemas que no formen parte de la aplicación web autorizada.
- Información o sistemas de terceros.
- Cualquier acción que pueda interrumpir el funcionamiento de la plataforma o afectar información real de los clientes.
- Infraestructura de la base de datos y su configuración interna, salvo autorización expresa.

3. AUTORIZACIÓN Y CONDICIONES

Permisos requeridos

Antes de comenzar las pruebas se debe contar con:

- Autorización formal y por escrito de Aurora Market para realizar pruebas sobre la aplicación web.
- Definición clara del alcance de la evaluación.
- Contacto responsable de Aurora Market durante la evaluación.
- Permiso para registrar y documentar las vulnerabilidades encontradas.

Condiciones acordadas

- Las pruebas se realizarán únicamente sobre la aplicación web autorizada.
- No se atacarán redes sociales, equipos personales, correos, proveedores externos ni otros sistemas fuera del alcance.
- No se realizarán acciones que puedan interrumpir el servicio.
- Se evitará afectar o modificar información real de los clientes.
- Las pruebas se realizarán preferentemente durante horarios de menor actividad.
- Los resultados y evidencias obtenidos deberán manejarse de manera confidencial.

4. TIPO DE PENTEST

Tipo de pentest elegido: Gray-Box

Justificación de la elección

El pentest será de tipo Gray-Box porque el equipo cuenta con información parcial sobre el objetivo. Aurora Market informó que posee una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios, pero no proporcionó detalles sobre la tecnología utilizada ni sobre cómo está construida la plataforma. Este enfoque permite evaluar la seguridad desde una situación intermedia: el equipo dispone de cierta información para orientar las pruebas, pero debe investigar otros aspectos durante el proceso. No corresponde a Black-Box porque ya se cuenta con información inicial de la plataforma, y tampoco a White-Box porque no se dispone de acceso al código fuente ni a las configuraciones internas.

5. PLANIFICACIÓN

Antes de comenzar las pruebas técnicas, el equipo debería realizar las siguientes tareas:

Objetivos

- Definir qué riesgos se quieren identificar.
- Determinar qué información y funcionalidades deben protegerse.

- Establecer los resultados esperados del pentest.

Alcance

- Identificar exactamente la aplicación web que será evaluada.
- Determinar qué funcionalidades, usuarios y componentes pueden ser analizados.
- Confirmar qué elementos quedan fuera del alcance.

Permisos y condiciones

- Verificar la autorización formal.
- Establecer las reglas de las pruebas.
- Definir horarios y contactos responsables.
- Determinar qué acciones están prohibidas para evitar interrupciones o daños.

Metodología a utilizar

Se propone utilizar OWASP Web Security Testing Guide (WSTG) como guía para organizar las pruebas de seguridad de la aplicación web.

Recopilación de información previa

La recopilación de información se realizará combinando fuentes internas y fuentes abiertas (OSINT):

- **Fuentes internas:** la información parcial que Aurora Market ya proporcionó (existencia de aplicación web, base de datos, autenticación y tipos de usuario), sumada a la exploración de la aplicación como usuario autenticado y no autenticado para conocer sus funcionalidades desde adentro.
- **Fuentes OSINT:** información pública sobre el dominio y la infraestructura visible desde afuera, dado que el equipo no cuenta con documentación técnica completa de la plataforma.

Herramientas propuestas y propósito de cada una:

- **Nmap:** identificar puertos abiertos y servicios expuestos en los activos autorizados de Aurora Market, para detectar si además de los servicios esperados existen otros accesibles desde Internet. Esto permite construir un primer mapa de la superficie de ataque.
- **Whois y herramientas de DNS (dig, nslookup):** obtener información del dominio, subdominios asociados y proveedor de hosting, lo cual puede revelar entornos adicionales (por ejemplo, entornos de prueba o paneles administrativos) que no fueron documentados por la empresa.
- **OWASP ZAP:** mapear la aplicación web, interceptar y analizar las peticiones HTTP, y detectar de forma automatizada vulnerabilidades comunes como inyección, configuración insegura de cookies o cabeceras de seguridad faltantes.
- **Wappalyzer / BuiltWith:** identificar las tecnologías utilizadas por la plataforma (framework, servidor web, CMS), lo que permite orientar la búsqueda hacia vulnerabilidades conocidas para esas versiones específicas.

Recursos necesarios

- Equipo autorizado para realizar las pruebas.
- Herramientas de análisis de seguridad (Nmap, herramientas de DNS/Whois, OWASP ZAP, Wappalyzer).
- Entorno de pruebas, cuando esté disponible.
- Registro de evidencias y resultados.
- Canal de comunicación con el responsable de Aurora Market.

Programación del pentest

Se propone realizar las pruebas en horario nocturno, entre las 00:00 y las 05:00 (hora local de México), de lunes a jueves. Esta franja se elige porque es previsible que concentre el menor tráfico de usuarios reales en

una plataforma de comercio electrónico orientada al público general, reduciendo así la probabilidad de que las pruebas interfieran con compras o consultas en curso, tal como exige la condición de Aurora Market de operar en horarios de menor actividad. Se evitan los fines de semana, dado que en e-commerce suelen concentrarse picos de tráfico por promociones. Cada sesión de pruebas será notificada previamente al contacto responsable de Aurora Market, manteniendo comunicación activa durante la ejecución por si fuera necesario pausar ante cualquier anomalía.

A nivel general, las pruebas se organizarán en las siguientes etapas: reconocimiento y recopilación de información, análisis de vulnerabilidades, explotación controlada, post-explotación y, finalmente, elaboración del informe.

6. FASES DEL PENTEST

1. Reconocimiento

En esta fase se buscará construir un mapa completo de la superficie de ataque de Aurora Market antes de analizar vulnerabilidades puntuales. Concretamente:

- Se realizará un escaneo de puertos con Nmap sobre los activos autorizados, para identificar qué servicios están expuestos públicamente: por ejemplo, si solo están abiertos los puertos esperados para HTTP/HTTPS, o si existen puertos adicionales —como los de una base de datos o un panel administrativo— accesibles desde Internet, lo cual sería un hallazgo relevante por sí mismo.
- Se identificarán subdominios y tecnologías utilizadas (framework, servidor web, CMS) mediante herramientas OSINT y de fingerprinting, ya que Aurora Market no compartió esta información; esto orienta qué vulnerabilidades conocidas buscar en la fase siguiente.
- Se navegará la aplicación como usuario autenticado y no autenticado para mapear todos los puntos de entrada: formularios de login y registro, carrito, checkout, historial de pedidos y panel de administración de empleados, prestando especial atención a cómo cada uno maneja parámetros e identificadores de usuario (por ejemplo, URLs o campos que incluyan un ID de cuenta), ya que son candidatos directos para investigar la falla de control de acceso reportada.
- Todos los hallazgos de esta fase se documentarán, dado que servirán de referencia para priorizar dónde enfocar el análisis de vulnerabilidades.

2. Análisis de vulnerabilidades

Para esta fase se utilizará OWASP ZAP en modo de escaneo activo y pasivo sobre los módulos identificados durante el reconocimiento, con el objetivo de detectar de forma automatizada vulnerabilidades comunes: inyección SQL, XSS, configuración insegura de cookies o sesiones, y cabeceras de seguridad faltantes. Esta herramienta permite obtener rápidamente un panorama amplio de fallas técnicas conocidas sobre toda la aplicación.

De forma complementaria, se realizará una revisión manual de control de acceso (búsqueda de vulnerabilidades tipo IDOR — Insecure Direct Object Reference), dado que el incidente reportado por Aurora Market apunta específicamente a esta categoría. Se analizará, por ejemplo, si los identificadores utilizados en el historial de pedidos o en el perfil de usuario presentan controles de autorización adecuados, ya que podrían constituir puntos de interés para investigar una posible vulnerabilidad IDOR.

El propósito de combinar herramienta automatizada y revisión manual es que los escáneres automáticos suelen tener baja efectividad para detectar fallas de lógica de negocio y de control de acceso —que requieren entender el contexto específico de la aplicación—, mientras que sí son eficientes para detectar vulnerabilidades técnicas conocidas y de rápida verificación. Todos los hallazgos se registrarán y clasificarán según su nivel de riesgo.

3. Explotación

Las vulnerabilidades identificadas —en particular la posible falla de control de acceso (IDOR) señalada por el incidente reportado— podrán ser verificadas mediante pruebas controladas para confirmar si son realmente explotables y dimensionar su impacto. Por ejemplo, si se detecta que es posible modificar el identificador de un pedido en la URL para acceder al pedido de otro usuario, se validará este comportamiento utilizando únicamente cuentas de prueba propias del equipo, nunca cuentas ni datos de clientes reales, y sin ejecutar ninguna acción que modifique información. La explotación se realizará siempre de forma segura, respetando las condiciones establecidas por Aurora Market y evitando cualquier impacto sobre el funcionamiento de la plataforma.

4. Post-explotación

Si una vulnerabilidad es explotada de forma controlada, se analizará hasta dónde podría llegar un atacante real y qué información o funcionalidades podría comprometer a partir de ese punto de entrada. Por ejemplo, en el caso del posible IDOR, se evaluará si el mismo tipo de falla permite acceder no solo al historial de pedidos, sino también a datos de perfil, direcciones u otra información sensible de otras cuentas, y si existe la posibilidad de que ese acceso permita alcanzar otras funcionalidades o privilegios dentro de la aplicación. Esta fase se realizará exclusivamente sobre cuentas de prueba propias, sin acceder ni exponer innecesariamente información real de los clientes.

5. Informe

Finalmente se elaborará un informe con:

- Vulnerabilidades encontradas.
- Evidencias de cada hallazgo.
- Nivel de riesgo e impacto.
- Descripción de las posibles consecuencias.
- Recomendaciones para corregir o reducir los riesgos.

Esto permitirá que el equipo de desarrollo de Aurora Market pueda revisar posteriormente los problemas encontrados y priorizar su corrección, que es uno de los objetivos centrales planteados por la empresa al contratar esta evaluación.

7. INVESTIGACIÓN

Metodología elegida: OWASP Web Security Testing Guide (WSTG)

OWASP WSTG es una guía orientada a realizar pruebas de seguridad sobre aplicaciones y servicios web. Organiza las pruebas en diferentes áreas, permitiendo realizar una evaluación de seguridad de manera estructurada.

¿Por qué sería útil para Aurora Market?

OWASP WSTG es una guía ampliamente utilizada para la evaluación de aplicaciones web. Ofrece un marco estructurado con pruebas específicas para evaluar el control de acceso, la gestión de sesiones y la validación de entradas, permitiendo analizar de manera rigurosa y sistemática el incidente de fuga de información entre cuentas de Aurora Market.